

Лабораторна робота №5. Автоматизація процесу в n8n і безпека агента

26 серпня 2026 р.

Мета

Зібрати робочу автоматизацію навчального процесу в самостійно розгорнутому n8n, підключити до неї локальну модель і власні інструменти, а потім атакувати власну систему і показати експериментально, які захисти справді тримають.

Робота виконується **бригадою з трьох осіб**. Лекції 10, 13, 18.

Усе безкоштовне. n8n у режимі self-hosted безкоштовний за ліцензією Sustainable Use для некомерційного й навчального використання; піднімається одним контейнером Docker. Модель — локальна через Ollama, тому жодного платного API і жодної хмарної підписки не потрібно.

Склад бригади і розподіл ролей

Кожен учасник відповідає за свою підсистему, має власний результат і захищає його окремо. Спільним є лише інтеграційний крок і підсумковий звіт.

- **Учасник А — інфраструктура і воркфлоу.** Піднімає n8n у Docker, будує основний воркфлоу з тригером, гілками і обробкою помилок, підключає локальну модель через вузол Ollama.
- **Учасник В — агент та інструменти.** Додає агентний вузол, підключає до нього інструменти й MCP-сервер із лабораторної 4, реалізує межу дозволених дій і підтвердження людини перед незворотним кроком.
- **Учасник С — атаки й захисти.** Складає набір сценаріїв prompt injection із машинно перевірюваними критеріями, міряє частку успішних атак до і після кожного захисту, готує evidence package.

Інтеграційний крок виконують разом: воркфлоу учасника А отримує агентний вузол учасника В, після чого учасник С атакує зібрану систему через дані, які надходять у воркфлоу ззовні. Схему меж довіри бригада малює спільно.

Теоретичні відомості

Воркфлоу і агент — це дві різні відповіді на питання, хто вирішує наступний крок. У воркфлоу маршрут намальований людиною, і модель викликається там, де її поставили; в агенті модель обирає послідовність дій сама. n8n дозволяє мати обидва режими в одній системі, і саме тому на ньому добре видно межу між ними.

- **Автоматизація має власні режими відмови**, незалежні від моделі: тригер спрацював двічі, зовнішній сервіс віддав 500, гілка обробки помилок не написана взагалі. Тому воркфлоу проєктують із явним шляхом помилки, а не лише зі щасливим сценарієм.
- **Недовірений текст стає інструкцією**. У звичайному застосунку потік керування зафіксований у коді, а недовірений ввід є даними для парсера. В агенті потік керування породжується з тексту, і текст цей приходить із документів, з відповідей інструментів і від інших агентів. Пряма інекція живе в запиті користувача, непряма — у даних, що входять у воркфлоу ззовні: у листі, у файлі, у рядку таблиці.
- **Смертельна тріада є булевою умовою:**

$$\text{Risk}_{\text{exfil}} = A \wedge B \wedge C$$

де A — доступ до приватних даних, B — контакт із недовіреним текстом, C — канал назовні. Правило Agents Rule of Two вимагає, щоб сеанс задовольняв **не більше двох** властивостей із трьох. Автоматизація небезпечна саме тим, що зводить усі три разом непомітно: тригер приносить чужий текст, агент має доступ до бази, а вузол відправлення листа стоїть у кінці.

- **Системний промпт не є межею безпеки**. Виміряна ефективність промптових захистів падає під адаптивною атакою: атакувальник ходить другим і бачить ваш захист. Надійний важіль архітектурний — обмежити *наслідок*, а не вхід: заборонити незворотну дію без підтвердження, розділити права, розірвати тріаду.
- **Двадцять сценаріїв — це пілот, а не вимірювання**. Одна атака важить п'ять відсоткових пунктів. Для кожного наслідку критерій успіху має бути машинно перевірюваним — рядок-маркер, факт виклику інструмента, поява захищеного значення у виході, — інакше підрахунок стане предметом суперечки.
- **Захисти міряють поодинці**. Увімкнені послідовно, вони змішують ефект конкретного механізму з порядком додавання, і приписати приріст стає нікому.

Корисні посилання для ознайомлення:

- [n8n: розгортання через Docker і ліцензія Sustainable Use](#);
- [Вузол AI Agent](#) та [вузол Ollama Chat Model](#) — модель локальна, ключі не потрібні;
- [Приклади AI-воркфлоу](#) в документації n8n;
- Greshake K. та ін. [Indirect Prompt Injection](#), AISec 2023;
- [OWASP Top 10 для LLM-застосунків](#) і [AgentDojo](#).

Порядок виконання

Позначка $[A]$, $[B]$, $[C]$ вказує відповідального за крок; **[разом]** — крок виконує вся бригада.

1. **[разом]** **Обрати реальний повторюваний процес** навчального відділу і описати його як тригер, кроки й результат.
2. **[A]** **Підняти n8n локально і зібрати воркфлоу** з тригером, умовною гілкою і явним шляхом обробки помилок. Воркфлоу має переживати перезапуск контейнера.

3. **[A] Ввести локальну модель у воркфлоу** як крок класифікації або підсумовування і зафіксувати, скільки часу він додає.
4. **[B] Додати агентний вузол з інструментами** — зокрема MCP-сервером із лабораторної 4 — так, щоб виклики було видно в журналі виконання.
5. **[B] Поставити межув незворотності** перед кроком, що діє назовні, і намалювати схему меж довіри вашої системи: звідки заходить недовірений текст, де приватні дані, де канал назовні.
6. **[C] Скласти 20 сценаріїв prompt injection** — половину непрямих, через дані, що заходять у воркфлоу ззовні, — із машинно перевірюваним критерієм успіху для кожного наслідку.
7. **[C] Виміряти частку успішних атак** до захисту і після кожного захисту окремо, а потім після всіх разом.
8. **[разом] Оформити ноутбук.** Зібрати роботу в один Jupyter-ноутбук: код кожного учасника у своїх комірках із короткими коментарями. Оскільки частина роботи живе поза кодом, у ноутбук вкладаються також експорт воркфлоу у JSON, схема меж довіри і скріншот журналу виконання зі спрацюванням захисту. Обов'язково всередині: набір сценаріїв разом із критеріями успіху, таблиця частки успішних атак до і після кожного захисту, і висновок до 250 слів із переліком того, що не закрилося. Окремо зазначити, що вибірка з 20 сценаріїв є пілотною.

Контрольні запитання

1. Чим воркфлоу відрізняється від агента з погляду того, хто обирає наступний крок?
2. Чому в автоматизації непряма інекція небезпечніша за пряму?
3. Які три властивості утворюють смертельну тріаду і яку з них дешевше зняти у вашій системі?
4. Чому системний промпт не є механізмом безпеки?
5. Навіщо міряти кожен захист окремо, а не всі разом?
6. Що таке машинно перевірюваний критерій успіху атаки і чому без нього підрахунок беззмістовний?
7. Тригер спрацював двічі на одному входному листі. Що має статися і що станеться без ідемпотентності?
8. Чому 20 сценаріїв не дають підстав стверджувати, що захист «працює на 90 %»?
9. Які сценарії з вашого набору неможливо закрити нічим, крім архітектури?
10. Що входить до evidence package і що саме кожен його елемент доводить?
11. Чому кожен захист міряють окремо, а не всі разом?

Література

1. Debenedetti E. та ін. [AgentDojo](#). NeurIPS, 2024.
2. Debenedetti E. та ін. [Defeating Prompt Injections by Design \(CaMeL\)](#), 2025.
3. Nasr M. та ін. [The Attacker Moves Second](#). arXiv:2510.09023, 2025.
4. NIST AI 600-1. [AI RMF: Generative AI Profile](#), 2024.